

Prime Stack Test Execution Report

Team: Prime Stack
Application under test: Frost Inventory and Shopping System
Report date: 14 May 2026

1. Execution Summary

Testing was performed for the Frost Inventory and Shopping System in the local development environment. The testing effort included automated backend functional tests, Playwright UI/usability scenarios, k6 performance and security scripts, and an OWASP ZAP automated scan of the backend API.

Execution date for ZAP evidence: 14 May 2026.

2. Test Environment

Item	Value
Backend	Express API on <code>http://localhost:3000</code>
Frontend	Angular app on <code>http://localhost:4200</code>
Database	MySQL database <code>frost</code>
Functional tools	Jest, Supertest
Frontend/usability tool	Playwright
Performance/security script tool	k6
Security scanner	ZAP by Checkmarx 2.17.0

3. Execution Results by Test Type

Test type	Planned	Executed / evidence	Result summary
Functional API tests	36	Test suites exist under <code>backend/tests/functionality</code>	Core user, product, supplier, and purchase workflows are covered
Frontend usability checks	3	Test suite exists at <code>frontend/tests/example.spec.ts</code>	Registration/login preparation, product browsing, and existing-user login are covered with screenshots
Performance tests	6	Script exists at <code>backend/tests/performance/load-test.js</code>	Thresholds defined: <code>p(95)<500ms</code> , error rate <code><10%</code>
Security scripted tests	7	Script exists at <code>backend/tests/performance/security-test.js</code>	Injection, access control, mass assignment, XSS payload, and payload resilience are covered
ZAP scan	1 scan	Evidence stored in <code>docs/testing/evidence</code>	4 alert types were reported

4. Functional Test Execution Notes

The backend tests are organized by module:

Test file	Coverage
backend/tests/functionality/user.test.js	Registration, login, duplicate email, missing fields, boundary validation, auth status
backend/tests/functionality/product.test.js	Product list, details, creation, duplicate detection, lookup, amount update, deletion
backend/tests/functionality/supplier.test.js	Supplier list, creation, duplicate detection, lookup, update, deletion
backend/tests/functionality/purchase.test.js	Purchase list, creation, missing fields, user history, sorting, purchased products

Current observation: DEF-001 has been fixed, but login failures still map to 500 in DEF-005. Purchase creation and purchase history also need attention because DEF-004 and DEF-002 affect purchase workflow reliability.

5. Frontend Usability Test Execution Notes

Frontend usability tests were written with Playwright. They cover:

- UT-001: New user registration/login preparation flow.
- UT-002: Product browsing/client dashboard flow.
- UT-003: Existing user login flow.

The Playwright tests save screenshots under frontend/tests/screenshots ; copies are included in this report's evidence folder.

6. Performance Test Execution Notes

The k6 load test defines this load profile:

Stage	Duration	Target virtual users
Normal load	30 seconds	5
Load ramp	1 minute	20
Stress	30 seconds	50
Recovery	30 seconds	0

Performance acceptance thresholds:

- 95% of requests should complete in under 500 ms.
- Error rate should stay below 10%.

Endpoints included: /User/status , /Product/ , /Product/getALL , /Supplier/ , and /User/login .

7. Security Test Execution Notes

The scripted security test covers:

- SQL injection on login.
- XSS payload in registration username.
- Unauthenticated profile access.
- Mass assignment attempt using role: "admin" .
- Oversized login payload.
- Unauthenticated access to /User/users .

The expected behavior for `/User/users` is `401 Unauthorized` , but the current route does not use authentication middleware. This is recorded as DEF-007. Mass assignment is recorded as DEF-006, and stored XSS input handling is recorded as DEF-008.

8. ZAP Scan Results

ZAP report details:

Attribute	Value
Tool	ZAP by Checkmarx
Version	2.17.0
Generated	Thu 14 May 2026, 14:16:40
Site	<code>http://localhost:3000</code>
Evidence file	<code>docs/testing/evidence/2026-05-14-ZAP-Security-Report-.html</code>

ZAP alert summary:

Alert	Risk	Confidence	URL	Evidence
CSP: Failure to Define Directive with No Fallback	Medium	High	GET <code>http://localhost:3000/robots.txt</code>	Content-Security-Policy: default-src 'none' missing frame-ancestors and form-action
Server Leaks Information via <code>X-Powered-By</code>	Low	Medium	GET <code>http://localhost:3000/robots.txt</code>	X-Powered-By: Express
<code>X-Content-Type-Options</code> Header Missing	Low	Medium	GET <code>http://localhost:3000/Product/</code>	Missing X-Content-Type-Options: nosniff
User Agent Fuzzer	Informational	Medium	GET <code>http://localhost:3000/Product/</code>	Response changed when using Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)

9. Confirmed Defects

ID	Title	Severity	Status
DEF-001	Missing fields return 500 instead of 400	Medium	Fixed
DEF-002	Template literal bug in <code>getPurchaseById</code>	Medium	Open
DEF-003	<code>SupplierRoute</code> POST has no error handling	Medium	Open
DEF-004	Purchase create fails when <code>userId</code> is passed from test	High	Open

ID	Title	Severity	Status
DEF-005	Login route hardcodes status 500	Medium	Open
DEF-006	Mass assignment allows any user to register as admin	Critical	Open
DEF-007	<code>/User/users</code> exposes all user data without authentication	High	Open
DEF-008	XSS payload stored in database without sanitization	Medium	Open
DEF-009	Missing security headers	Low	Open

10. Overall Assessment

The application has meaningful automated coverage for core API and frontend component behavior. The main quality risks are concentrated in security hardening and API error semantics:

- Sensitive routes should consistently require authentication and role checks.
- Invalid client input should return 4xx responses instead of generic 500 errors.
- Public registration must not accept privileged fields such as `role`.
- User-controlled text should be validated or sanitized before storage/display.
- Security headers should be centralized with middleware.
- Express technology disclosure should be disabled.

11. Evidence List

Evidence	File
ZAP full report	<code>docs/testing/evidence/2026-05-14-ZAP-Secuirty-Report-.html</code>
ZAP main screenshot	See image below
CSP screenshot	See image below
X-Powered-By screenshot	See image below
X-Content-Type-Options screenshot	See image below
User Agent Fuzzer screenshot	See image below
UT-001 screenshots	See images below
UT-002 screenshots	See images below
UT-003 screenshots	See images below
DEF-001 before/after images	<code>docs/testing/evidence/def-doc/word/media/</code>

May 14 14:12
Untitled Session - ZAP 2.17.0

File Edit View Analyse Report Tools Import Export Online Help

Standard Mode

Sites

Contexts

Default Context

Sites

Quick Start

Request

Response

Requester

Automated Scan

This screen allows you to launch an automated scan against an application - just enter its URL below and press 'Attack'. Please be aware that you should only attack applications that you have been specifically given permission to test.

URL to attack: Select...

Use traditional spider: ☒

Use ajax spider:

Never with Firefox

Attack

Stop

Progress: Attack complete - see the Alerts tab for details of any issues found

History

Search

Alerts

Output

Spider

Active Scan

Alerts (4)

CSP: Failure to Define Directive with No Fallback (2)

GET:http://localhost:3000/robots.txt

GET:http://localhost:3000/sitemap.xml

Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s) (3)

GET:http://localhost:3000/Product/

GET:http://localhost:3000/robots.txt

GET:http://localhost:3000/sitemap.xml

X-Content-Type-Options Header Missing

GET:http://localhost:3000/Product/

User Agent Fuzzer (Systemic)

GET:http://localhost:3000/Product/

GET:http://localhost:3000/Product/

GET:http://localhost:3000/Product/

GET:http://localhost:3000/Product/

GET:http://localhost:3000/Product/

GET:http://localhost:3000/Product/

X-Content-Type-Options Header Missing

URL: http://localhost:3000/Product/

Risk: Low

Confidence: Medium

Parameter: x-content-type-options

Attack:

Evidence:

CWE ID: 693

WASC ID: 15

Source: Passive (10021 - X-Content-Type-Options Header Missing)

Input Vector:

Description:

The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.

Other Info:

This issue still applies to newer browsers (103, 103, 500, etc.) as these browsers are often still affected by injection issues, in which case there is still concern for

Alerts 0 1 2 1 Main Proxy: localhost:8080

Current Status 0 0 0 0 0 0 0 0 0

ZAP automated scan overview

CSP: Failure to Define Directive with No Fallback

URL: http://localhost:3000/robots.txt

Risk: Medium

Confidence: High

Parameter: Content-Security-Policy

Attack:

Evidence: default-src 'none'

CWE ID: 693

WASC ID: 15

Source: Passive (10055 - CSP)

Alert Reference: 10055-13

Input Vector:

Description:

The Content Security Policy fails to define one of the directives that has no fallback. Missing/excluding them is the same as allowing anything.

Other Info:

Current Status 0 0 0 0 0 0 0 0 0

ZAP CSP alert evidence

Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)

URL: http://localhost:3000/robots.txt

Risk:  Low

Confidence: Medium

Parameter:

Attack:

Evidence: X-Powered-By: Express

CWE ID: 497

WASC ID: 13

Source: Passive (10037 - Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s))

Input Vector:

Description:

The web/application server is leaking information via one or more "X-Powered-By" HTTP response headers. Access to such information may facilitate attacking other frameworks/components your web application is reliant upon and the vulnerabilities such components may be subject to.

Other Info:

Current Status 

ZAP X-Powered-By alert evidence

X-Content-Type-Options Header Missing

URL: http://localhost:3000/Product/

Risk:  Low

Confidence: Medium

Parameter: x-content-type-options

Attack:

Evidence:

CWE ID: 693

WASC ID: 15

Source: Passive (10021 - X-Content-Type-Options Header Missing)

Input Vector:

Description:

The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.

Other Info:

This issue still applies to error type pages (401, 403, 500, etc.) as these pages are often still affected by injection issues, in which case there is still concern

Current Status 

ZAP X-Content-Type-Options alert evidence

User Agent Fuzzer

URL: http://localhost:3000/Product/

Risk:  Informational

Confidence: Medium

Parameter: Header User-Agent

Attack: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)

Evidence:

CWE ID: 0

WASC ID: 0

Source: Active (10104 - User Agent Fuzzer)

Input Vector:

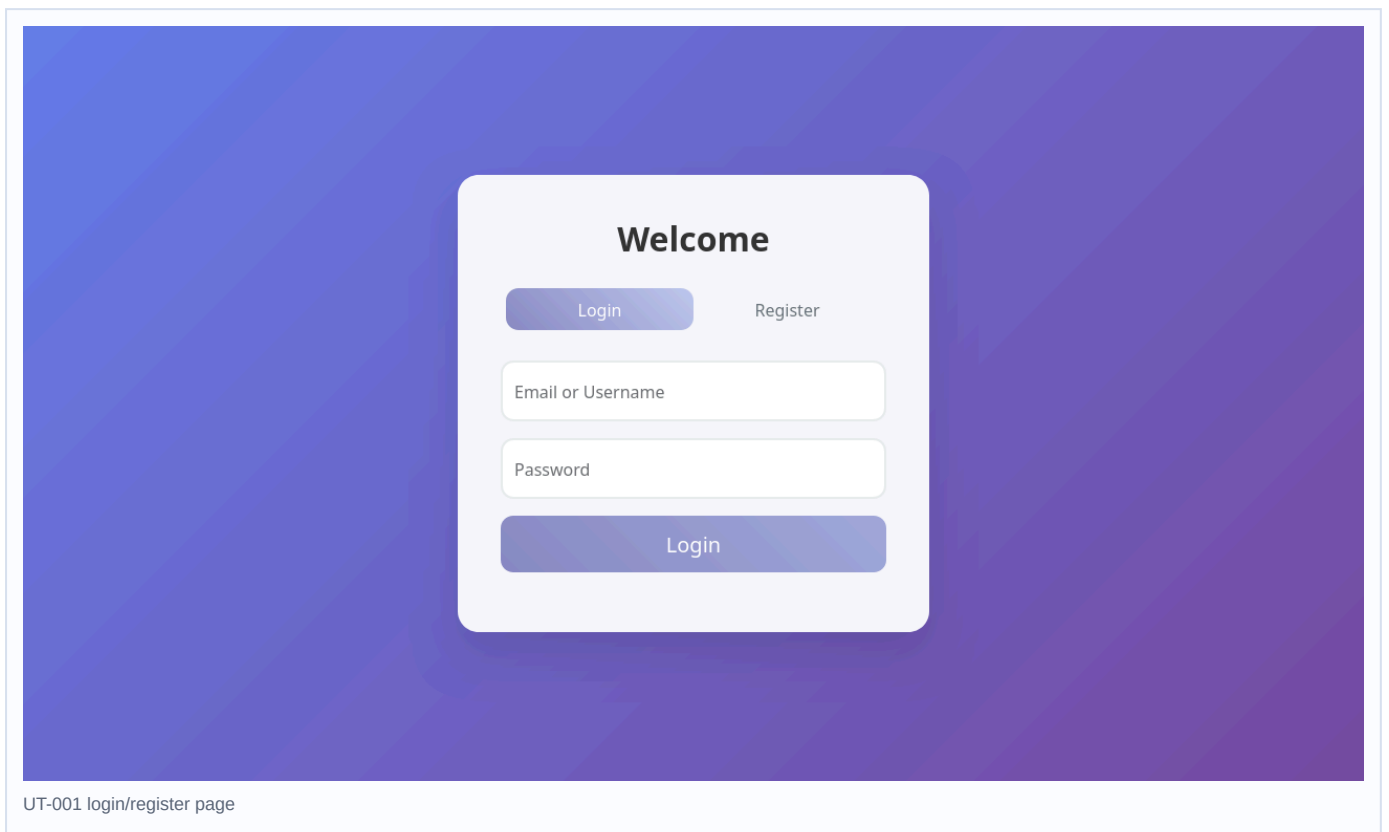
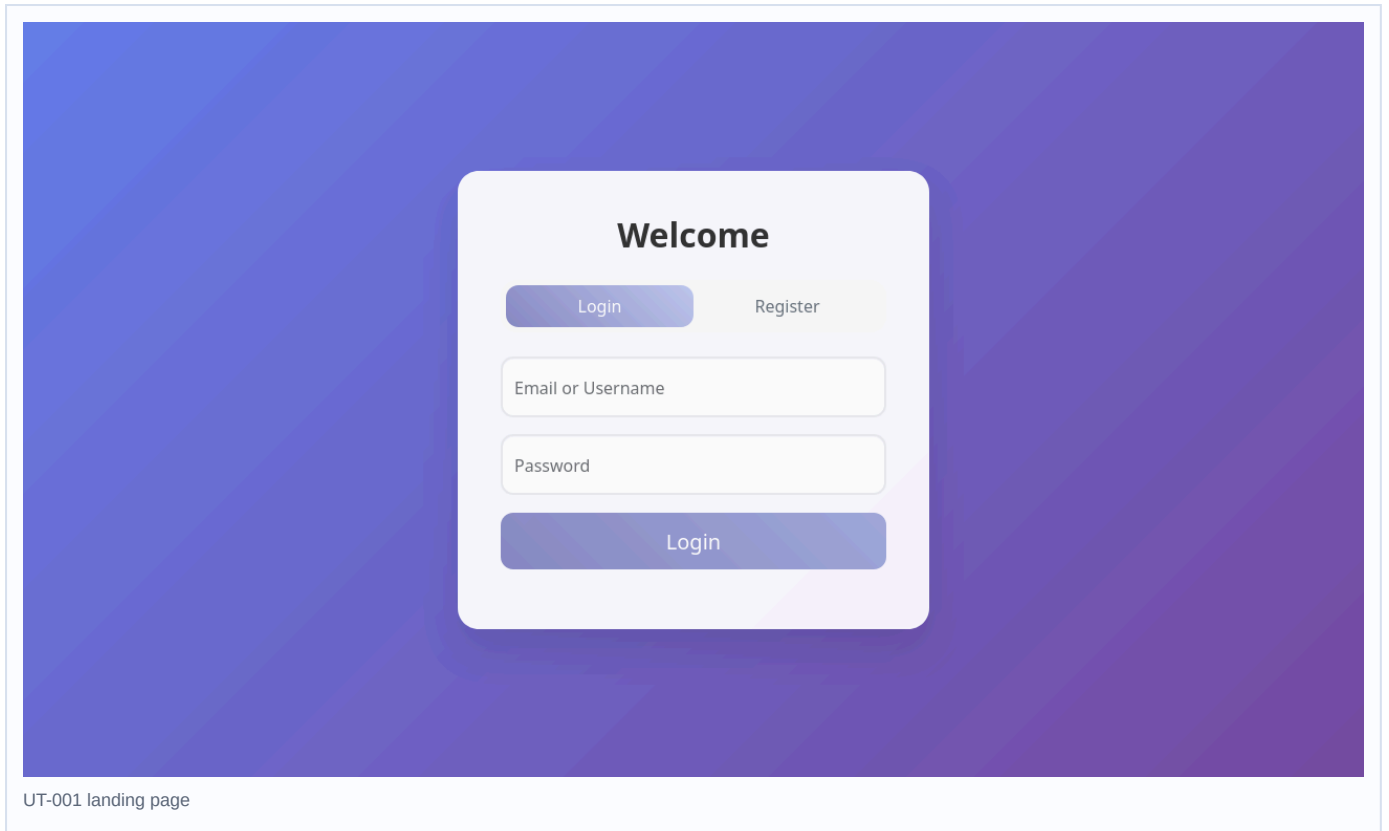
Description:

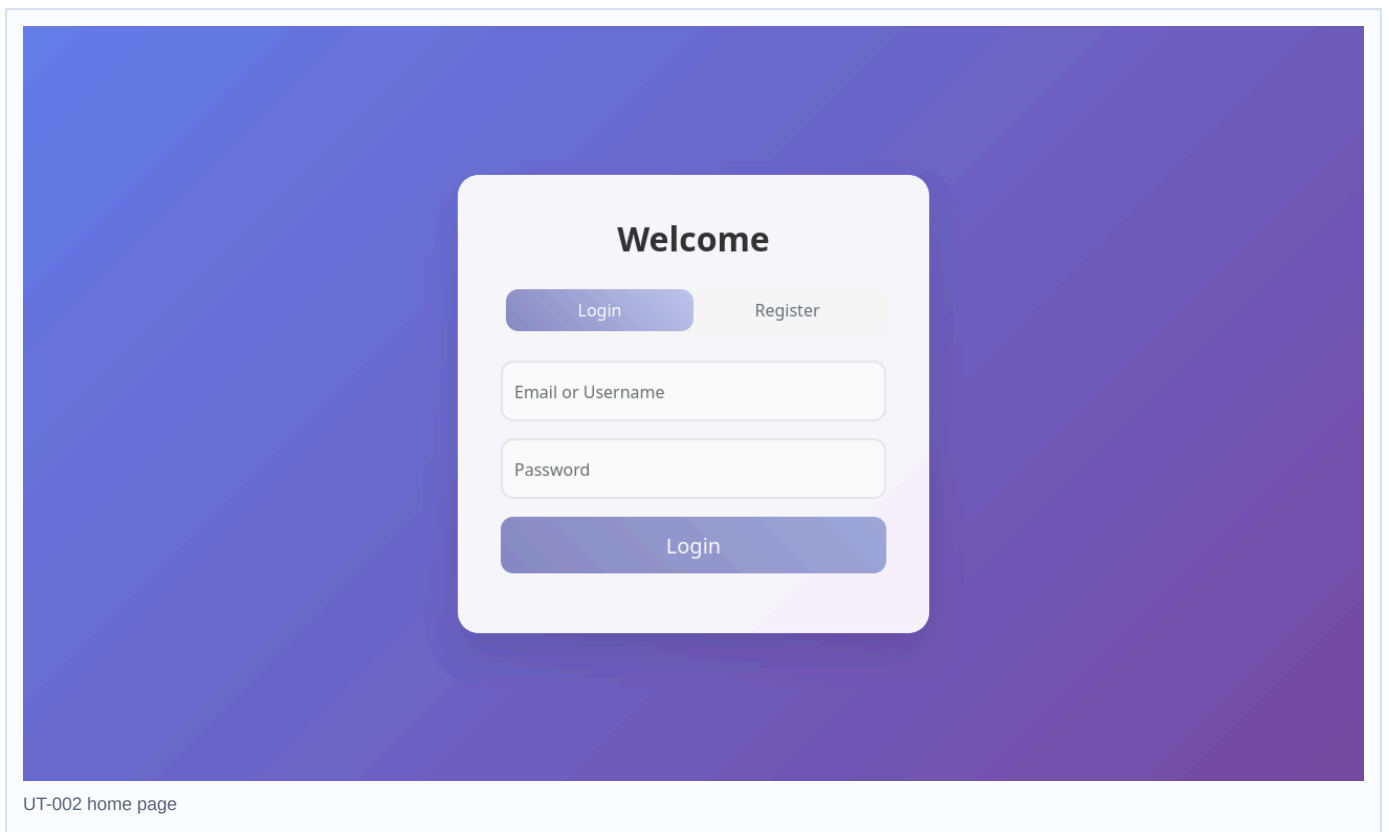
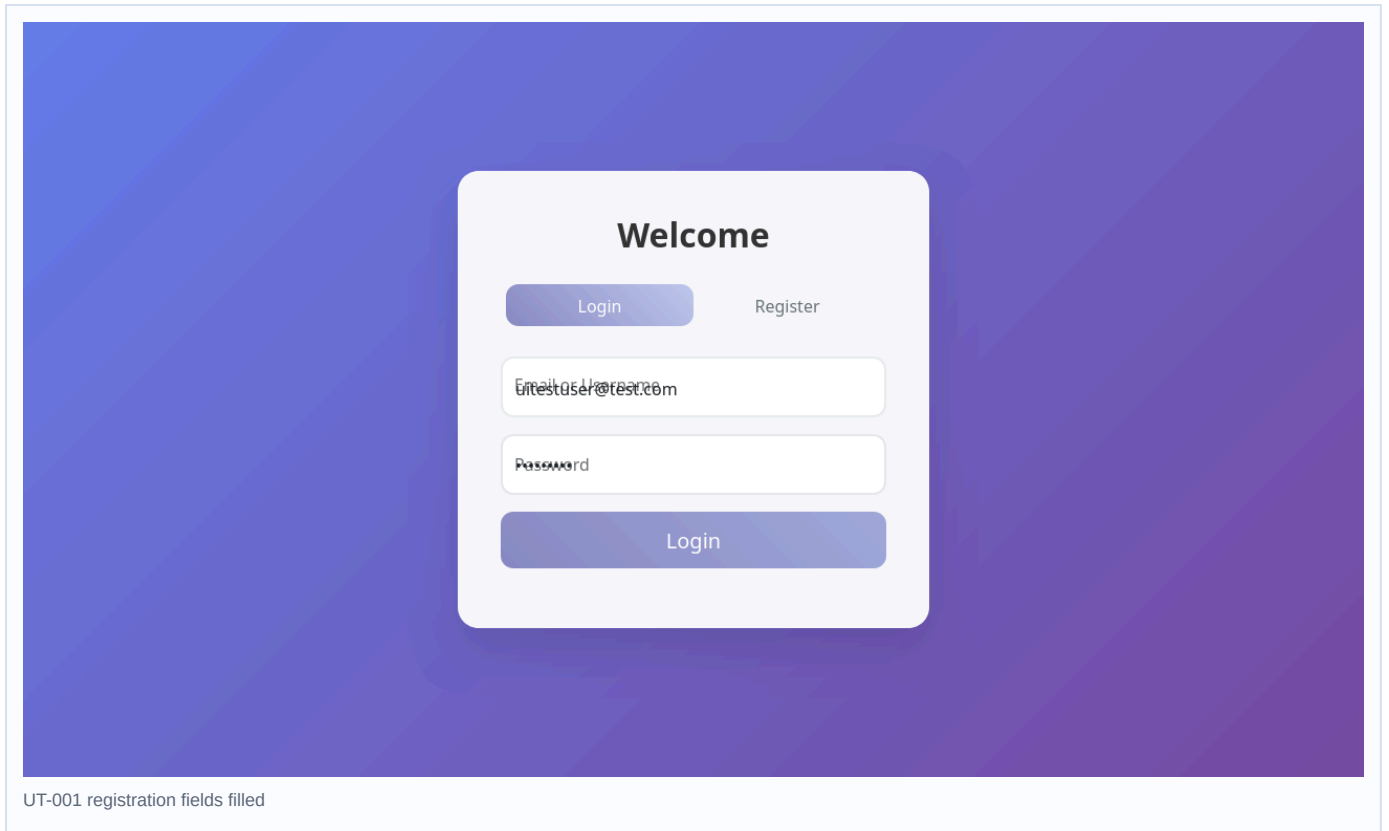
Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as a Search Engine Crawler). Compares the response statuscode and hashcode of the response body with the original response.

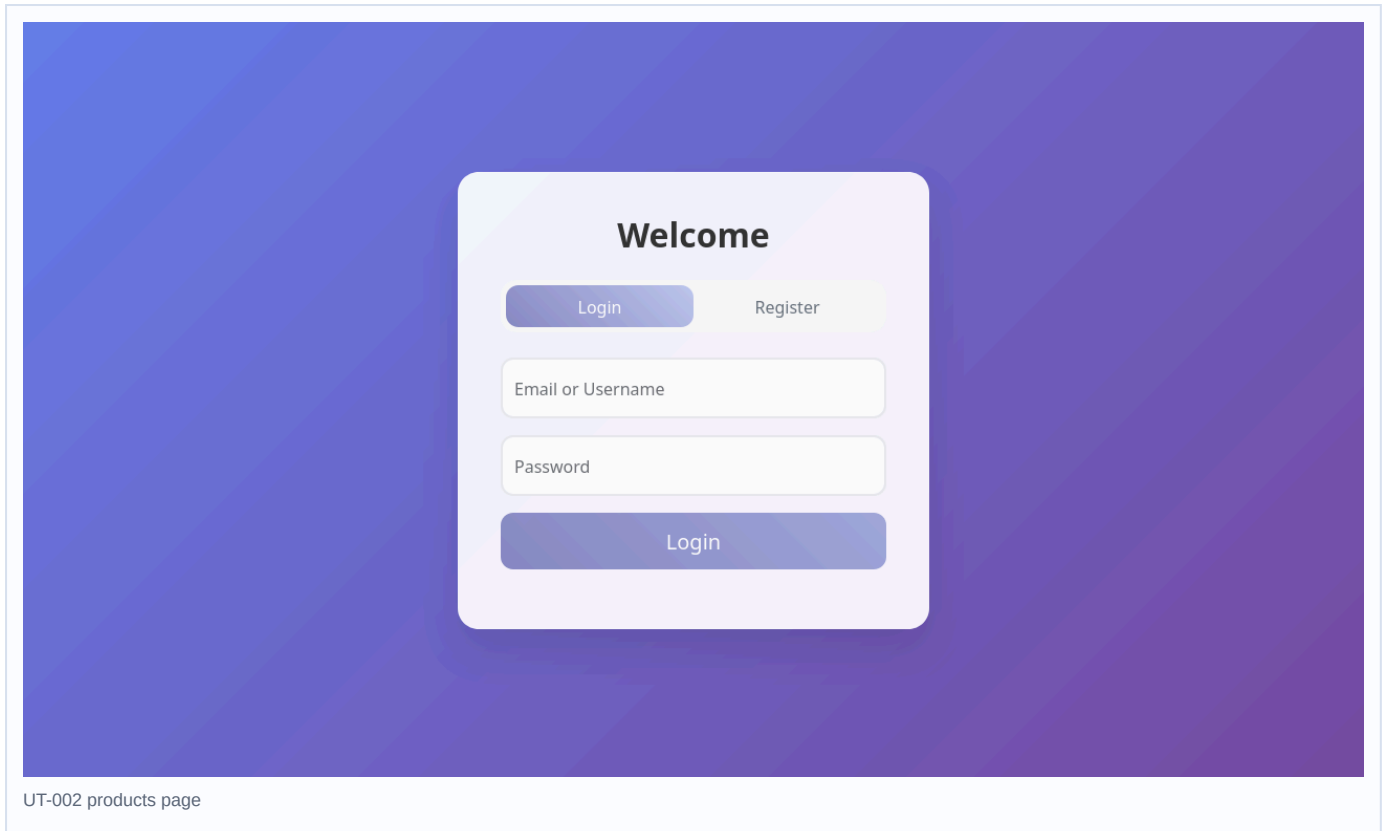
Other Info:

Current Status 

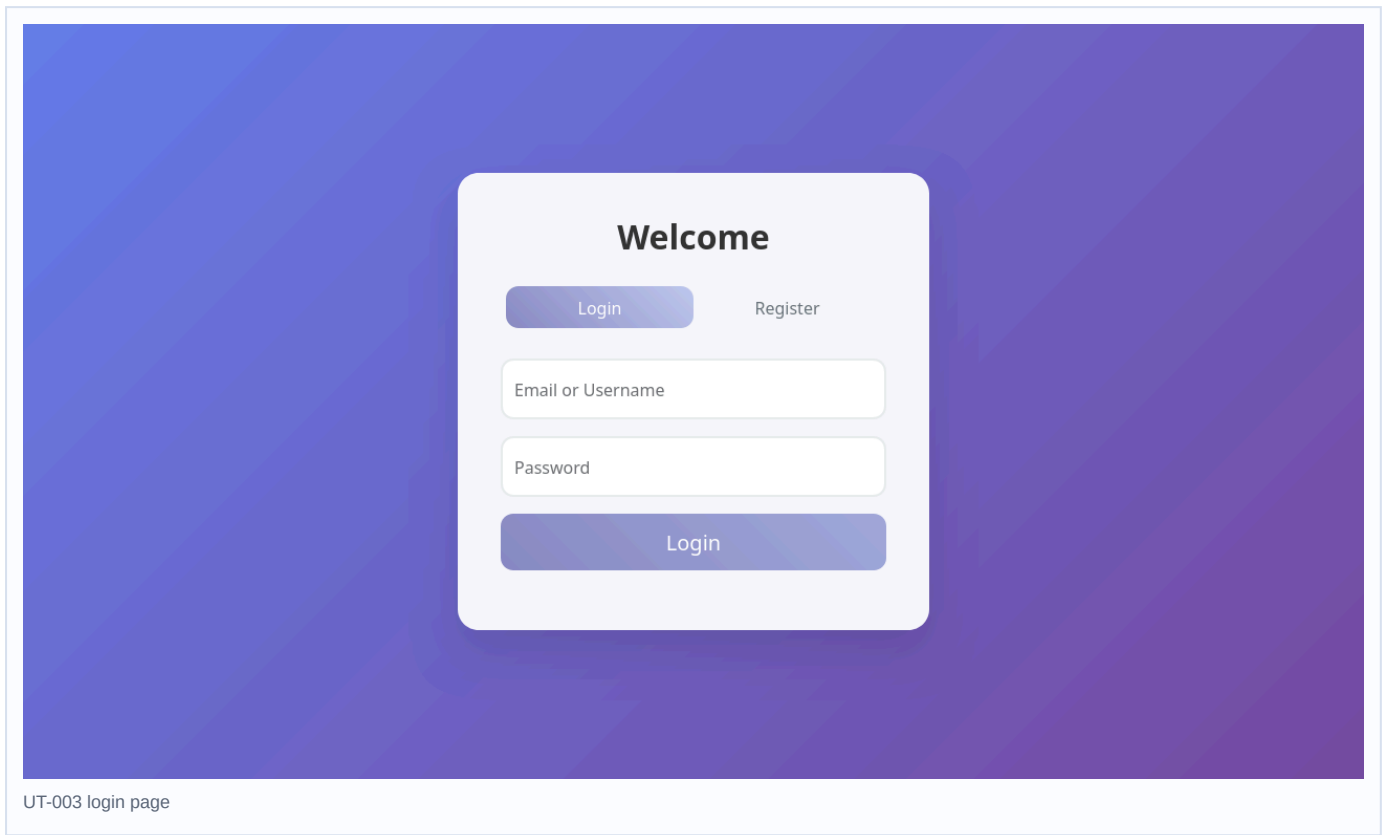
ZAP User Agent Fuzzer alert evidence







UT-002 products page



UT-003 login page

